

The Vulnerability Management Lifecycle

Why Vulnerability Management Is a Program, Not a Scan

A scan alone changes nothing. The **program** is the loop that turns "there are vulnerabilities" into "they are managed":

Discover → Assess → Prioritize → Remediate → Verify → Report



The Six Steps

1. Discover – know what you own

Asset inventory (the elephant in the room: you can't secure what you don't know exists)

Scanning, agents, cloud configuration APIs, CMDBs

Continuous discovery of new/shadow IT

2. Assess – find the vulnerabilities

Scanner (Nessus/OpenVAS/Qualys/Rapid7) produces finding lists

Agent-based vs network scanning

False positive verification (M10 lesson 3)

3. Prioritize – decide what to fix FIRST (the whole art)

NOT "fix highest CVSS first" – context beats number

CVSS + exploitability + asset value + business impact

4. Remediate – patch, configure, mitigate, accept

Patch (vendor fix) is most common; configuration change; remediation plan; compensating control; or formal risk acceptance

5. **Verify** – rescan to confirm closure

6. **Report** – to decision-makers in business language (risk in, risk out)

The Metrics of VM

MTTR for critical findings (how fast does critical get patched?)

% of criticals open > 30 days

Re-opened findings (patch failed / bypass)

Scan coverage % (assets scanned)

Vulnerability density (per system or per department)

The 2026 Rule of Thumb

Automation is HOW you scale:

Auto-inventory (agents + cloud APIs)

Auto-patch for baseline OS patching (Patch Tuesday rhythm)

Auto-risk-score the findings (the priority problem solved by a machine that combines CVE data)

Blue-team truth: your vulnerability program's worst day isn't "critical" findings piling up – it's "nobody told me we had that server," i.e. inventory failure. Discovery is the foundation.

[← Module start](#)

[Prioritization: CVSS, EPSS & C...](#)